

CVEs más relevantes de la semana

Del 30/06/2026 al 07/07/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-10560

Descripción: IBM Langflow OSS 1.0.0 through 1.9.6 contains a missing authentication vulnerability in /api/v1/build_public_tmp/ endpoints that allows an unauthenticated attacker to read build event data or cancel jobs using a valid job identifier, resulting in information disclosure and denial of service.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-11546

Descripción: IBM WebSphere Application Server - Liberty 17.0.0.3 through 26.0.0.7 is affected by a server-side request forgery vulnerability with the adminCenter-1.0 feature enabled.

CVSS: 7.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:H

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-11714

Descripción: IBM WebSphere Application Server - Liberty 17.0.0.3 through 26.0.0.7 is affected by a server-side request forgery vulnerability with the apiDiscovery-1.0 feature enabled.

CVSS: 8.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-13449

Descripción: IBM Business Automation Manager Open Editions 9.0.0 through 9.4.2 is vulnerable to an XML external entity injection (XXE) attack when processing XML data. A remote attacker could exploit this vulnerability to expose sensitive information or consume memory resources.

CVSS: 7.6 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:H

Tipo: CWE-611

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-13772

Descripción: IBM WebSphere Extreme Scale 8.6.1.0 through 8.6.1.6's Object Query Language engine resolves attacker-supplied class names via Class.forName() and invokes their constructors with no allow-list at three distinct sinks (SELECT NEW, enum literals, and reflection-based comparators); an authenticated remote attacker who can influence an application-built OQL query string can execute arbitrary constr...

CVSS: 7.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-470

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-13773

Descripción: IBM WebSphere Extreme Scale 8.6.1.0 through 8.6.1.6

Approximately 50 generated CORBA stub classes in WebSphere eXtreme Scale's ogclient.jar call ORB.string_to_object() on an attacker-controlled IOR string during Java deserialization, turning any unfiltered ObjectInputStream sink in WAS into outbound IIOP SSRF to an attacker-chosen host; when chained with the IBM ORB's getUserException class-ins...

CVSS: 6.0 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:L/I:L/A:L

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-7663

Descripción: IBM Langflow OSS 1.0.0 through 1.9.6 could allow unauthenticated attackers to access protected MCP project resources and execute MCP operations due to improper authorization enforcement in the Streamable MCP transport endpoint.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-285

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-11541

Descripción: IBM WebSphere Application Server 9.0, and 8.5 and IBM WebSphere Application Server - Liberty 17.0.0.3 through 26.0.0.6 are affected by an HTTP request smuggling vulnerability.

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-444

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-13775

Descripción: Use after free in GPU in Google Chrome prior to 150.0.7871.47 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Critical)

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-13776

Descripción: Type Confusion in Dawn in Google Chrome prior to 150.0.7871.47 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Critical)

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-843

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-13780

Descripción: Insufficient validation of untrusted input in ANGLE in Google Chrome prior to 150.0.7871.47 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Critical)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-13781

Descripción: Insufficient validation of untrusted input in Skia in Google Chrome prior to 150.0.7871.47 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Critical)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-13782

Descripción: Use after free in Browser in Google Chrome prior to 150.0.7871.47 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Critical)

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-13785

Descripción: Use after free in Bluetooth in Google Chrome on Mac prior to 150.0.7871.47 allowed a remote attacker who convinced a user to engage in specific UI gestures to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Critical)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-14101

Descripción: Insufficient policy enforcement in Sandbox in Google Chrome on Mac prior to 150.0.7871.47 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Low)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-14104

Descripción: Insufficient validation of untrusted input in WebAppInstalls in Google Chrome prior to 150.0.7871.47 allowed a remote attacker to execute arbitrary code inside a sandbox via a crafted HTML page. (Chromium security severity: Low)

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-14106

Descripción: Insufficient validation of untrusted input in Text in Google Chrome on Android prior to 150.0.7871.47 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Low)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-14109

Descripción: Insufficient policy enforcement in Mojo in Google Chrome prior to 150.0.7871.47 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Low)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-14120

Descripción: Inappropriate implementation in DevTools in Google Chrome prior to 150.0.7871.47 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Low)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-30



CVE-2026-34100

Descripción: Guardian language-system passes the id GET parameter directly into an unsanitized SQL query in media.php (line 17):

```
SELECT id, filename, extension, type, duration, owner, private  
FROM files where id = '\".$_GET['id'].\"'. An authenticated  
attacker can perform error-based SQL injection to extract database  
contents.
```

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-07-01



CVE-2026-34106

Descripción: Guardian language-system passes the id GET parameter directly into a PHP exec() call in subtitles.php (line 19) without sanitization: `exec(\"php jobs/subtitle_rendering.php \". $login_session.\" \".\"$_GET['id'].\" ...\")`. No authentication is required. An unauthenticated remote attacker can append shell metacharacters to the id parameter to execute arbitrary OS commands on the server.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-07-01



CVE-2026-58453

Descripción: JAIOTlink C492A-W6 Wi-Fi IP cameras running firmware 4.8.30.57701411 contain a hard-coded credentials vulnerability that allows network-adjacent attackers to gain unauthorized access by using the default admin username with an empty password accepted by the anyka_ipc HTTP service on port 80. Attackers can authenticate with these hardcoded credentials to access camera snapshots, video streams, n...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1392

Tecnología: No especificado

Publicado el: 2026-07-01



CVE-2026-58521

Descripción: Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in The Wikimedia Foundation Mediawiki - Cargo Extension allows SQL Injection.

This issue affects Mediawiki - Cargo Extension: from * before 1.43.9,1.44.6,1.45.4.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-07-01



CVE-2026-50195

Descripción: containerd is an open-source container runtime. Versions prior to 2.3.2, 2.2.5 and 2.1.9 contain a vulnerability in the CRI checkpoint import process where it fails to validate the image references specified within a checkpoint image's configuration. An attacker with permissions to create pods can use a crafted checkpoint image to force containerd to pull a malicious image and assign it an arbi...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-345

Tecnología: No especificado

Publicado el: 2026-07-01



CVE-2026-53492

Descripción: containerd is an open-source container runtime. In Versions prior to 2.3.2, 2.2.5 and 2.1.9, the CRI implementation improperly trusts Container Device Interface (CDI) annotations found within untrusted checkpoint image metadata during container restoration. When restoring a container from a checkpoint, containerd preserves CDI-related annotations from the checkpoint archive rather than relying ...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-07-01



CVE-2026-54408

Descripción: A malicious actor with access to the network could exploit an Improper Access Control vulnerability found in UniFi Protect Application to bypass authentication for data streaming.

CVSS: 8.6 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-07-02



CVE-2026-55115

Descripción: A malicious actor with access to the network and low privileges could exploit a Server-Side Request Forgery (SSRF) in UniFi Protect Application to escalate privileges on the host device.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-07-02



CVE-2026-26145

Descripción: Improper access control in Azure Synapse allows an authorized attacker to elevate privileges over a network.

CVSS: 4.8 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:U/C:H/I:N/A:N

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-07-02



CVE-2026-41106

Descripción: Url redirection to untrusted site ('open redirect') in M365 Copilot allows an unauthorized attacker to elevate privileges over a network.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-601

Tecnología: No especificado

Publicado el: 2026-07-02



CVE-2026-9725

Descripción: The Printcart Web to Print Product Designer for WooCommerce plugin for WordPress is vulnerable to Arbitrary File Deletion in versions up to, and including, 2.5.2 This is due to insufficient path validation in the store_design_data() function, which constructs a filesystem path from the user-supplied 'nbd_item_key' POST parameter sanitized only with sanitize_text_field() — which does not strip p...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-07-03



CVE-2026-57983

Descripción: Improper authorization in Microsoft Edge (Chromium-based) allows an unauthorized attacker to bypass a security feature over a network.

CVSS: 8.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-285

Tecnología: No especificado

Publicado el: 2026-07-03



CVE-2026-14345

Descripción: The WPFunnels – Funnel Builder for WooCommerce with Checkout & One Click Upsell plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 3.12.7 via the 'postData' parameter parameter. This is due to unsanitized write of attacker-controlled postData values into a PHP-includeable .log file combined with the use of include_once to render that file in wpfnl_...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-07-07



CVE-2026-13019

Descripción: Esri Portal for ArcGIS versions 12.1 and earlier on Windows, Linux and Kubernetes have a missing authentication for critical function vulnerability allows a remote, unauthenticated attacker to access an unprotected API.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-640

Tecnología: No especificado

Publicado el: 2026-07-07



Resumen del Reporte

CVEs analizados: 33

Promedio CVSS: 8.99

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

